

Login, session, and the minimum intake path

Six plates for what **P2 actually builds** — gate **G2**, spec decision #14: login plus the minimum intake path, **not** the four-step registration wizard. Wizard UI decided before the P3 design system exists is UI built twice.

Rendered in Direction F (docs/design/05–design–tokens.md) with all four \$6 corrections applied — `—accent-fill 717:1`, `—separator 304:1`, `—border-strong 310:1`, disabled accepted at 2.56:1 and compensated, Dense density, the provisional default. Structure traces to 03–key–flows.md flow 1 and 04–wireframes.md plate 4; where these plates depart from those, the note says so.

Ships in: PR 2 (session + login) · PR 3 (contract truth + intake) **Light only** by P0.5 §7 **No web fonts** — system stacks, every set below

TYPE SET A · F as drawn B - no serif C · grotesk D - humanist **E · Charter serif — chosen**

Every plate below re-renders in the chosen set. Only the two family tokens and heading tracking change — sizes, weights, spacing and colour are held fixed, so the difference on screen is the typeface alone. The drafting board itself does not change.

0 The five type sets, side by side evaluation only — 05–design–tokens.md §3 still pins A

A · SERIF DISPLAY (DIRECTION F)

Register a patient

Maria Gonzalez · verified at the desk

MEDICAL RECORD NUMBER

RB-00417821974-03-02

B · NO SERIF — SYSTEM UI

Register a patient

Maria Gonzalez · verified at the desk

MEDICAL RECORD NUMBER

RB-00417821974-03-02

C · NO SERIF — GROTESK

Register a patient

Maria Gonzalez · verified at the desk

MEDICAL RECORD NUMBER

RB-00417821974-03-02

D · NO SERIF — HUMANIST

Register a patient

Maria Gonzalez · verified at the desk

MEDICAL RECORD NUMBER

RB-00417821974-03-02

E · SERIF KEPT — CHARTER/CAMBRIA

Register a patient

Maria Gonzalez · verified at the desk

MEDICAL RECORD NUMBER

RB-00417821974-03-02

- A — Direction F as drawn.** `ui-serif`, “Iowan Old Style”, Palatino, Georgia on headings and the patient name, system sans everywhere else. The serif is F’s argument; it marks the identity strip and page titles as document rather than instrument, which is why §3 rations it and keeps it out of queue rows.
- B — the serif removed, nothing else changed.** One system UI stack throughout; headings survive on size and weight, tightened `—,014em` because `SF/Sege` at 29px tracks looser than Palatino does. Cheapest possible answer to “how does it look without” — and the only set that removes a whole failure mode, since a heading and its body can no longer fall back to different families on an unusual workstation.
- C — grotesk.** Colder and narrower; reads as instrument, not document — closest to what clinical software normally looks like, which is either the point or the objection. Widest install base here: Helvetica or Arial is present on every platform, so what a Windows desk sees is what a Mac sees.
- D — humanist.** Keeps F’s warmth without a serif. Open apertures hold up better than the grotesk at the 11px uppercase label step, which is the smallest type in the system. ❤️ **Cost:** this set resolves to a genuinely different face per platform (Avenir Next on macOS, Segoe UI Variable on Windows, Corbel behind it), so the render is *not* stable across workstations the way B and C are. **Correction, 2026-08-01:** this line originally said “the way A, B and C are”, which was wrong about A. A leads with the `ui-serif` *generic*, whose mapping is per-browser and not inspectable, and names `Palatino`, which does *not* match Windows’ `Palatino Linotype` — so a Windows workstation fell through to Georgia by accident, not by choice. A was never platform-stable; it only looked it. E is per-platform too (Charter on macOS, Cambria on Windows), but both outcomes are named, screen-drawn faces rather than one named face and one accident.
- E — serif kept, changed.** **Chosen 2026-08-01.** The original argument on this line was that Charter and Cambria were drawn for screen text at *small sizes* — true, but largely spent, because §3 rations the serif to 18px and up and keeps it out of queue rows. The argument that survives is **DPI, not size**: Charter (Carter, 1987) was cut for 300dpi laser output, low stroke contrast and sturdy stems; Cambria was commissioned for ClearType and is among the most aggressively screen-hinted serifs shipped. Palatino and Iowan Old Style carry high thick/thin contrast whose thinners fall below one pixel at 1x/96dpi and drop out or smear — so the gap widens on exactly the older clinic hardware this has to run on, and it does not close at 18px. Second reason, and the decider: **this stack is more predictable than A** (see below).
- Nothing here is decided — superseded.** 05–design–tokens.md §3 now pins set E, amended 2026-08-01 with the reasoning and the measured font-availability evidence, and a new §6.5 recording the low-DPI margins that decided it. This page followed §3, as this line always said it would: the default set above is E. It still does not own the decision — if the set changes again, §3 changes first.

1 Sign in GET /login FE-R27FE-R30FE-R31

RiverbendCommunity Health · staff portal

Sign in

For Riverbend staff. Patients do not have accounts here.

USERNAME

frontdesk

PASSWORD

Sign in

Riverbend signs you out after 10 minutes without activity.

- The form posts to the portal’s own server, never to the gateway.** That server holds the gateway bearer token and returns a sealed session cookie — `httpOnly`, `SameSite=Lax`, no `Max-Age`, no `Domain` attribute (FE-R38). Secure is **derived from the deployment’s** `ORIGIN` scheme, not `hardcoded: hardcoded true` on a non-localhost HTTP origin makes the browser discard the cookie silently and every later request arrives unauthenticated with no error to read.
- Nothing about the session is readable from JavaScript** (FE-R27). Today’s portal writes the token to `localStorage` — the pattern OWASP and SMART on FHIR both name specifically as the thing not to do.
- The logout interval is stated on the login surface**, before it can surprise anyone mid-form. 10 minutes, per ADR 0014 §4.
- No “forgot password”, no “remember me”, no self-registration.** No such endpoint exists, and dead affordances teach operators the interface lies (wireframe plate 1 note 5).
- 🔴 No copy addresses the operator as a patient (FE-R13 | FE-R24). Today’s dashboard opens “Good day, Front” and offers “a summary of your care”.

2 Sign-in refused, and sign-in unavailable POST /login → failure FE-R2FE-R16

RiverbendCommunity Health · staff portal

Sign in

For Riverbend staff. Patients do not have accounts here.

That sign-in did not work

The username or password is not recognised. Check both and try again.

USERNAME

frontdesk

Re-enter the username and password.

PASSWORD

Sign in

Sign-in is unavailable

The portal could not reach the sign-in service. Nothing was changed. Try again in a moment; if it keeps failing, tell the help desk.

Try againReference c7f4-1e

- Two different failures, two different messages.** A refused credential is the operator’s to fix; an unreachable gateway is not, and telling them to “check the password” wastes the shift.
- Both branches arrive as HTTP 200.** The gateway’s `_post / _get return r.json()` regardless of downstream status, so a rejected login is `200 + {“detail”: …}` and a transport failure is `200 + {“error”: str(e)}`. FE-R2 names all three branches — `non-2xx`, `detail` body, `error` body — because the second was in the original wording and the third was not.
- 🔴 **The upstream string is never rendered.** `str(e)` can carry hostnames, connection strings and payload fragments; FE-R16 forbids PHI in an operator-facing error, and this is the cheapest place to leak it. The correlation reference is for the log, and the log line is what carries the detail.
- 🔴 **No username enumeration.** One message for a bad username and a bad password.
- The password field clears; the username survives. Cross-flow rule 6 — preserve operator input across failure — with the one exception every browser already expects.

3 Signed out after 10 minutes idle any route → /login FE-R28driven at 62

RiverbendCommunity Health · staff portal

Signed out

There was no activity for 10 minutes, so Riverbend ended the session on the server. Sign in again to carry on.

USERNAME

frontdesk

PASSWORD

Sign in

- The timeout is enforced server-side from** `last_seen` **inside the sealed cookie**, a value the browser cannot forge. A client timer alone is a suggestion. ADR 0014 §4.
- The portal calls the existing** `POST /logout`, which destroys the gateway’s session. A timer that only clears client state leaves a live, unexpiring credential behind — `create_session` sets no TTL.
- The redirect is not the proof.** FE-R28’s gate evidence is a request made after the timeout coming back 401; the CI half is unit tests on the timer and the status check, both pure functions. Same split as FE-R27 and half of FE-R29 — the harness has no server, no database and no network, so anything verified “after login” is **driven at the gate and written down**. G2’s signature rests on that record.
- The reason is stated.** A silent bounce to login reads as a bug and gets reported as one.
- Open, not decided:** whether a warning precedes the logout. ADR 0014 specifies none. A front-desk operator mid-registration losing ten minutes of typing is the argument for one; it is also new state and a new failure mode, so it is a decision, not an edit.
- 🔴 **This does not close D10.** The Redis session still has no TTL. A token captured before the timer fires stays valid forever, and only the gateway can fix that.

4 Register a patient GET /intake FE-R12FE-R21FE-R11FE-R29

RiverbendCommunity Health · staff portal

Signed in as frontdeskSign out

Register a patient

One page for now. The search-first entry and the four-step review land with the P3 design system, not here.

The person

FIRST NAMELAST NAME

MariaGonzalez

DATE OF BIRTHSEXSSN

1974-03-02Female*****4412

Type it — YYYY-MM-DD.Stored unencrypted today (D3).

Insurance

PAYERMEMBER IDGROUP

Meridian Health PlanMRD4417820RB-2201

☒ The policy holder is the patient

Clear this only to record that someone else holds the policy. Riverbend cannot store that person’s name today.

Consents

Riverbend records what was accepted. Declined and not answered are kept apart on screen; neither writes a row.

Notice of privacy practices acknowledged

AcceptedDeclinedNot answered

✓ Accepted

Consent to treat

AcceptedDeclinedNot answered

✓ Accepted

Financial responsibility

AcceptedDeclinedNot answered

✗ Declined

Contact by email and text

AcceptedDeclinedNot answered

○ Not answered

Register this patientDiscard

Eligibility is checked during registration, so this can take a few seconds.

- Four consents, and every one of them is storable** (FE-R21). That is what the P2 backend half buys: `ConsentKind` widens from three to five with `financial_responsibility_ack` and `communications_opt_in`. Today the form takes a financial attestation and the service discards it. The fifth member, `ro1_consent`, is collected by no UI at all — which is why FE-R21’s test is a **subset** assertion plus a pinned-literal enum, not set equality.
- Three consent states on screen, one in the data** (FE-R11). The `consents` table has no status column — `_record_consents` inserts one row per accepted kind and nothing else — so “Declined” and “Not answered” are indistinguishable in storage by *construction*. Keeping them apart is a UI obligation the data cannot help with, and the copy above says exactly what is written rather than implying more. The chips derive from the §2 rule, unchanged: tint for a settled answer, dashed outline for one that never came, glyph on every chip so the column survives greyscale.
- SSN is “type=“text”** (FE-R12). Today it is `type=“password”`, so the browser’s password manager offers to save a patient’s SSN into a workstation profile. `autocomplete=“off”`, and the field states its own posture — plaintext `TEXT` in Postgres, D3, unchanged by the rebuild.
- The policy-holder name is gone, replaced by the bit that is actually consumed.** Measured, not assumed: the only consumer is `policy_holder_is_self: true`. `policy_holder` — a boolean derived from emptiness — and the name string reaches nothing but a review display. Collecting PHI-shaped free text that no column stores is worse than not collecting it. The checkbox’s helper line is the honest half: unchecking it records the fact and loses the name.
- Typed date of birth**, no picker. The native picker opens on the current year and reaching 1974 means dropdown hunting; FE-R7 owns the real fix at G3, and a text field with a stated format is the P2 floor, not the answer.
- Nothing here is written to** `localStorage`, `sessionStorage` **or IndexedDB** (FE-R29). Draft-preservation across a refresh would be a patient record at rest on a shared clinic workstation.
- Not in P2, deliberately:** search-first entry (FE-R6, G3), the duplicate-match step, per-section review with edit. Registration opening on a blank form is the RIV-160 duplicate generator, and it stays open until P4.

5 Registration failed POST /intake → 200 + detail FE-R2FE-R16

RiverbendCommunity Health · staff portal

Signed in as frontdeskSign out

Register a patient

Maria Gonzalez was not registered

Riverbend rejected the registration and created no record. Everything entered is still here. Try again — if it fails a second time, send the reference below to the help desk.

Try againReview the entry

Reference a91b-7d · 14:22

NAMEDATE OF BIRTHPAYER

Maria Gonzalez1974-03-02Meridian Health Plan

Nothing was written. No patient record, no consent, no eligibility check.

- This is the defect the whole rebuild is named after.** On `main` today, `intake-service` returns 422, the gateway relays it as HTTP 200, and the portal prints “Intake submitted successfully” over a patient that does not exist. It shipped past `npm run build` and 730 passing tests because nothing asserted the two sides of the payload.
- 🔴 **A 200 is not proof** (cross-flow rule 2). The portal treats a `detail` body, an `error` body, or a missing `patient_id` as failure regardless of status.
- The failure names the patient and states what was not written.** “Every write shows what it wrote” runs in both directions — an operator who cannot tell whether a record exists will either create a duplicate or skip a real registration.
- Every entered field survives**, and “Review the entry” returns to the form populated (FE-R2, cross-flow rule 6). 🔴 Never a cleared form.
- The validation detail is not rendered.** A 422 body echoes the submitted payload — names, dates of birth, member IDs — so printing it puts PHI on a waiting-room screen and into any screenshot of it (FE-R16).
- The three branches are not equally reachable, which the test fixture has to respect.** The `error` branch is not produced by a slow payer — `ELIGIBILITY_TIMEOUT_SECONDS` is 8s inside `_post`’s 30s httpx timeout, so ADR 0010 returns `pending`. It is reachable when `intake-service` is down or restarting. The fixture is “intake unreachable”, not “payer slow”.

6 Registered — what was written POST /intake → 200 + patient_id FE-R1FE-R28FE-R3

RiverbendCommunity Health · staff portal

Signed in as frontdeskSign out

Maria Gonzalez is registered

The record exists and can be found by name from now on.

NAMEDATE OF BIRTHMRN

Maria Gonzalez1974-03-02RB-0041782

PATIENT IDCONSENTS RECORDEDALLERGIES

10742 of 4 accepted

Not captured by the interface feed

INSURANCE ELIGIBILITY

Unknown

Meridian Health Plan · member MRD4417820

The payer did not answer in time, so coverage is unconfirmed — not refused. Check again now, or carry on and check later.

Check eligibility againOpen this patient

A registration cannot be edited after this point — Riverbend has no update path today.

- The confirmation states what was created**, not “success” (FE-R1, cross-flow rule 1): identity, MRN, `patient_id`, how many consents were recorded, and the eligibility result.
- The eligibility result is already in the response and currently thrown away** (FE-R28). Surfacing it is a rendering change; moving the check off the request thread is D4’s remaining half and is approval-gated — out of scope here.
- 🔴 **Unknown is never rendered as “not covered.”** ADR 0010 returns `pending` / `unknown` on payer trouble rather than a false `inactive`, precisely so a covered patient is not turned away at the desk. “Unknown” takes the solid attention chip because it is the state that needs a person; the copy says *unconfirmed, not refused* in words.
- Allergies read “not captured by the interface feed”, not blank** (FE-R5). HL7 AL1 segments are dropped upstream (D6), so silence and “none known” are different clinical facts and must never render alike.
- Post-submit correction is honestly unavailable.** No update endpoint exists, so no edit affordance is faked (flow 1 *xd*).
- The payload behind this screen is the shared fixture** (FE-R3): `tests/contracts/intake_payload.json`, asserted by a pytest test and a JS test, sitting outside both frontends. It is what stops the two sides drifting again — and it is the enforcement of the dropped `policy_holder` key, which no FE-R3 covers by decision.

What these plates do not show

- Everything behind G3 and later.** Name-and-DOB search (FE-R6), the persistent identity banner (FE-R4), the four-step wizard with per-section review, role-aware navigation (FE-R14, behind G4 and an explicit auth approval), appointment and ROI queues with clinic-time rendering (FE-R8 – R10).
- Any change to the gateway,** `require_session` is never asked to accept a cookie and no gateway file is edited — that invariant is the whole reason a server-held token is available at P2 instead of at G4.
- The IDOR fix.** Removing the numeric ID box is a read-path affordance, not an authorization change. Sequential patient IDs stay walkable until W4 binds a session to a patient.
- A patient-facing surface.** Blocked on that same session binding, not on frontend work.
- Small-viewport behaviour.** Unverified since P0.4 — Chrome would not resize below ~1500px during the walkthrough, so the narrow stage has unknown status and nothing here is a mobile decision.

Canonical decisions live in docs/design/03–key–flows.md, 04–wireframes.md and 05–design–tokens.md; requirements in docs/specs/frontend-rebuild.md §5. This page renders them — it does not own them. If it disagrees with those files, this page is behind.